INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — Genel Sürüm · Şişeleme Hattı

Tüm laboratuvarlar gün boyu gelişen tek bir örnek makine — jenerik şişeleme hattı — üzerinde işlenir.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

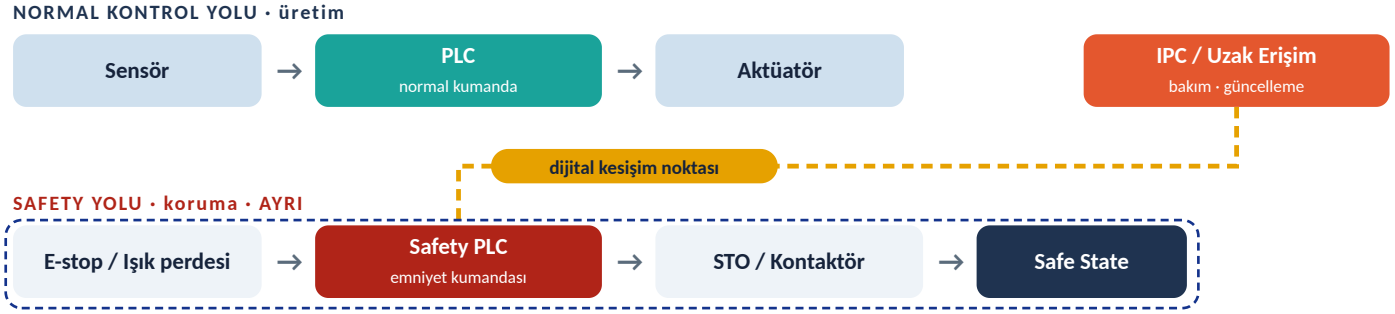
LABORATUVAR 1 · GENEL SÜRÜM · Şişeleme Hattı

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, **dijital bir konfigürasyona** bağlıdır.



Görev — sırayla cevaplayın

1. Bu makinede tehlike nedir? İnsan neyden zarar görür?

   Hareketli konveyör, dolum/kapama ünitesi ve robot kolu; operatör sıkışma, ezilme, kesilme ve çarpma ile zarar görür.

2. Safety function (emniyet fonksiyonu) hangisidir?

   E-stop / ışık perdesi → Safety PLC → STO ile tehlikeli hareketi durdurma (koruyucu kapı açıkken robot ve konveyör durur).

3. Safety-related control system nerede? Şemada işaretleyin.

   Kırmızı safety yolunda: E-stop / ışık perdesi + Safety PLC + STO / kontaktör (şemada kesikli çerçeveyle işaretlendi).

4. Normal PLC ile Safety PLC farkı nedir?

   Normal PLC üretimi sürer; Safety PLC ayrı çalışır, çift kanallı ve öz-tanılamalıdır, arızada güvenli duruma gider.

5. PLr / SIL neden var? Bu fonksiyon için neden önemli?

   Risk ne kadar yüksekse emniyet fonksiyonunun hatasız çalışma güvenilirliği o kadar yüksek olmalı; PLr/SIL bu hedefi belirler.

6. Safe state (güvenli durum) nedir?

   Tehlikenin ortadan kalktığı durum: enerji kesik (STO), hareket durmuş; arıza veya enerji kaybında sistem buna kendiliğinden döner.

7. Safety function hangi dijital bağımlılıklara sahip?

   Safety PLC programı/konfigürasyonu (mühendislik istasyonu), firmware, ağ bağlantısı, IPC / uzak erişim, servis hesapları, parametreler ve sinyal senkronu.

8. Siber müdahale hangi noktadan bu fonksiyonu bozar?

   IPC / uzak erişim (dijital kesişim noktası): ele geçirilen servis hesabıyla Safety PLC konfigürasyonu değiştirilir veya bypass edilir; safety yolu ağdan ayrılmamışsa E-stop/STO devre dışı kalabilir.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · GENEL SÜRÜM · Şişeleme Hattı

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

PLC · HMI · Robot kontrolörü · **Safety PLC** · SCADA istemcisi · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı (ERP/e-posta)

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

   Üretim (OT) bölgesi: PLC, HMI, Robot kontrolörü, SCADA istemcisi · Safety bölgesi: Safety PLC · Mühendislik/Bakım bölgesi: Mühendislik istasyonu, Uzak servis erişimi (DMZ üzerinden) · Kurumsal bölge: Ofis ağı (ERP/e-posta).

2. Safety PLC'yi hangi bölgeye koydunuz — neden?

   Ayrı Safety bölgesine: kritikliği en yüksek, insan güvenliği ona bağlı; yalnızca izinli ve sınırlı sinyal geçişi olmalı, diğer bölgelerden doğrudan erişim olmamalı.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

   Ofis↔DMZ, DMZ↔Üretim, Mühendislik/Uzak erişim↔Üretim, Üretim↔Safety. Her geçişte: güvenlik duvarı kuralı, izinli protokol/port/yön, MFA'lı jump server, oturum kaydı.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server — tek kontrollü giriş, doğrudan erişim yok
Tünel?	Açık / VPN	VPN — şifreli ve doğrulanmış kanal
Kimlik?	Parola / MFA	MFA — çalınan parola tek başına yetmez
Hesap?	Paylaşılan / Kişisel	Kişisel — izlenebilir sorumluluk, paylaşılan hesap yok
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı — olay sonrası kanıt ve denetim
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı — yalnızca onaylı bakım penceresinde açık

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · GENEL SÜRÜM · Şişeleme Hattı

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Saldırgan → ele geçirilen servis hesabı / uzak erişim → Safety PLC parametresi değiştirilir, E-stop etkisiz → operatör hareketli robota/konveyöre sıkışır	2	3	3	18	Kritik
Zafiyetli firmware güncellemesi → Safety PLC kütüphanesi bozulur → bakımda hat beklenmedik çalışır → teknisyen yaralanır	1	3	2	6	Orta · S=3 → öne alındı
Ofis ağından fidye yazılımı → SCADA / HMI → hat durur, reçete kaybolur → üretim kaybı (insana zarar yok)	3	1	3	9	Yüksek

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Senaryo 1 — skoru 18 (Kritik) ve sonucu insanda ağır yaralanma; safety yolu bozulursa başka koruma kalmaz.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, Senaryo 2 (1×3×2 = 6, Orta): S=3 olduğu için kayıtta "S=3" bayrağıyla üst sıraya alıp ayrıca işaretler, Yüksek/Kritik gibi izlerim.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · GENEL SÜRÜM · Şişeleme Hattı

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

Teknisyen/tedarikçi paylaşılan parolayla internetten doğrudan IPC'ye bağlanıyor; bağlantı sürekli açık, kayıt yok; IPC aynı düz ağda PLC ve Safety PLC'ye erişebiliyor.

HEDEF (beş ilkeyle yeniden tasarlayın)

Jump server + VPN + MFA + kişisel hesap + tam oturum kaydı; erişim varsayılan kapalı, onaylı pencerede açılır; IPC DMZ'de, Safety PLC ayrı bölgede.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Etkilenmemeli: Safety PLC ayrı bölge/ağda, uzak erişimden doğrudan erişilemez ve fonksiyonu normal kontrole bağlı değildir. Yine de konfigürasyonu değişirse risk doğar; bu yüzden safety konfigürasyonu ayrıca korunmalı.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

   Gereksinim: Emniyet fonksiyonu, normal kontrol sistemi, IPC ve uzak erişim ele geçirilse de güvenli duruma geçmeli; safety konfigürasyonu yalnızca yetkili, kayıtlı ve fiziksel anahtarla değiştirilebilmeli.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih 12.10.2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   SBOM ile üç şart: bileşen var mı, sürüm 2.4 etkileniyor mu, açık ağdan ulaşılabilir mi; üçü de evetse etkilenirim.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam: önce erişilebilirlik ve etkiyi değerlendirir, geçici önlemle riski düşürür, yamayı bakım penceresine alırım.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: ayrı test PLC'sinde / dijital ikizde denerim, sonra geri dönüş planıyla planlı bakım penceresinde uygularım.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet etkileyebilir: firmware safety yazılımını/zamanlamasını değiştirirse; satıcı notu + değişiklik etki analiziyle anlar, gerekirse yeniden doğrularım.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Ağ segmentasyonu/güvenlik duvarıyla bileşene erişimi kapatmak, uzak erişimi varsayılan kapalı tutmak, MFA'lı jump server, gereksiz servisleri kapatmak, izleme/alarm ve yama gelene kadar sıkı log takibi.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · GENEL SÜRÜM · Şişeleme Hattı

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih 12.10.2026

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Vardiya amiri/OT güvenlik sorumlusunu, bakımı ve BT güvenliğini ararım. İlk üç eylem: (1) emniyet kontrolü — gerekirse hattı güvenli durdur; (2) şüpheli hesabı/uzak erişimi izole et; (3) saati ve olayı kaydet, kanıtı koru (reset yok).

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   Safety fonksiyonlarını (E-stop, STO) test ederim; PLC konfigürasyonunu, logları ve ağ kayıtlarını yedekleyip korurum; servis hesabını kapatıp parola/anahtarları değiştiririm.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Ne oldu, ne zaman fark edildi, etkilenen sistem, şüpheli hesap/zafiyet, ilk etki ve alınan acil önlemler.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden ve etki: BT/OT güvenlik; önlem/yama: bakım; bildirim metni ve resmî iletişim: yönetim/yasal.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Erişim/oturum logları, PLC konfigürasyon yedekleri (önce/sonra), hesap işlemleri, ağ trafiği, alarm kayıtları, zaman damgaları.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · GENEL SÜRÜM · Şişeleme Hattı

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad | Grup | Tarih 12.10.2026

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Kamera → YZ Modeli → OK / RED → Parametre → Robot

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

   Çıkışı doğrudan kabul etmem: ikinci bağımsız kontrol (ikinci sensör/ölçüm) ve örneklemeli insan onayı olur; şüpheli parça reddedilir, hat güvenli duruma gider. Güvenliği YZ değil mimari sağlar.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

   Girdi doğrulama ile (görüntü kalitesi/bütünlük, kamera sağlık kontrolü, aralık ve referans karşılaştırma) fark edilir. Şüpheli girdide YZ kararı kullanılmaz: dur/RED, insana bildir, fallback.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

   Eşik risk analizi ve test verisiyle belirlenir (örn. ≥ %95). Altında: parça RED/ayrı alan + insana sor; çok düşükse dur (fallback güvenli mod). Otomatik OK verilmez.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	İkinci kontrol + insan onayı (human override) + monitoring; hatalı OK'ta lot ayrılır, hat fail-safe durur.
Girdi manipüle edildi	Girdi doğrulama + monitoring ile fark edilir; şüpheli girdide fail-safe: robot güvenli durum, parça RED, insan bilgilendirilir.
Confidence düştü	Confidence threshold: eşik altı → dur / insana sor / fallback (manuel kontrol); otomatik OK verilmez.

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.